

Privacy-Preserving LLM Inference via PII Masking

1st Raveena Kumari

*Communication Systems and Networks
TH-KÖLN*

Köln, Germany

raveena_kumari.kumari@smail.th-koeln.de

2nd Sneha Pillai

*Communication Systems and Networks
TH-KÖLN*

Köln, Germany

sneha_dayanandan.pillai@smail.th-koeln.de

I. ABSTRACT

Public large language models (LLMs) can assist with healthcare documentation tasks such as summarization, patient explanations, referral note preparation, and lab result explanation. However, healthcare prompts frequently combine personally identifiable information (PII) with clinically meaningful content. Sending such raw prompts to an external LLM provider creates privacy risks. This report presents a prototype privacy-preserving anonymization proxy that sits between a healthcare application and a public LLM. The proxy detects direct identifiers and selected quasi-identifiers, resolves conflicts between general named-entity recognition and biomedical entity recognition, masks private values with placeholders, preserves medically relevant terms, checks policy decisions before inference, validates the LLM response, and applies a final output filter. The prototype is implemented in Python using rule-based patterns, controlled synthetic-entity lists, Microsoft Presidio, spaCy, SciSpaCy BC5CDR, a mock LLM for reproducible evaluation, and Groq API mode for real public LLM demonstration. The system is evaluated on 30 synthetic healthcare prompts. The results show that the implemented approach can remove direct identifiers from prompts while retaining clinical context such as diseases, symptoms, medications, and lab findings. The prototype also identifies higher-risk prompts using WARN decisions for quasi-identifier combinations such as pregnancy with age/gender or rare disease with small-location context. The main conclusion is that a local anonymization proxy can reduce direct PII exposure before public LLM inference while preserving enough medical context for useful LLM-assisted documentation in a controlled synthetic setting.

Index Terms—privacy-preserving LLM inference, PII masking, healthcare prompts, anonymization proxy, Presidio, spaCy, SciSpaCy, Groq API, response validation, quasi-identifiers.

II. INTRODUCTION

Large language models are increasingly useful for text-heavy workflows [1]. In healthcare-like workflows, a clinician or healthcare user may ask an LLM to summarize a note, explain a lab result, prepare referral information, or rewrite a patient-facing explanation. The challenge is that the same prompt may contain both sensitive identifiers and important clinical context. For example, a prompt may include a patient name, date of birth, phone number, hospital, medical record number, and disease name in a single sentence [2]. The

identifiers should not leave the trusted environment, but the disease name and symptoms may be essential for producing a meaningful answer. A naive solution is to redact everything that looks sensitive. However, full redaction can remove useful information and produce weak or generic LLM responses. Another naive solution is to send the original prompt to the public LLM and rely on the provider’s privacy policy, but this does not satisfy the principle of data minimization. The prototype in this report follows a middle path: direct identifiers are masked or generalized, while clinically meaningful concepts are preserved whenever possible. The project implements a privacy-preserving LLM proxy. The proxy receives a healthcare prompt, detects PII and biomedical entities, masks identifiers, checks whether the masked prompt is safe enough to send, sends only the masked prompt to an LLM backend, validates the returned response, replaces placeholders with safe generic labels, performs a final leakage check, deletes the session mapping vault, and records metadata-only audit events.

III. RESEARCH QUESTION

A. Motivation

The main motivation is the privacy-utility trade-off. If the proxy masks too little, sensitive information may leave the trusted boundary. If it masks too much, the prompt may lose the clinical meaning needed for a useful LLM response. For example, removing a patient name is normally necessary, but removing a disease name such as diabetes or Parkinson’s disease may make the LLM answer less useful. Similarly, exact dates of birth are direct identifiers, but approximate age may still be relevant in healthcare contexts. The prototype therefore attempts selective masking: direct identifiers are masked, while medical concepts are preserved when possible [3], [4].

B. Research Question

The central research question of this work is: Can an automated Anonymization Proxy effectively strip PII without destroying the context needed for the LLM to provide a high-quality answer?

This question is operationalized using four sub-questions. First, which information should be masked and which should be preserved? Second, can the system prevent direct identifiers from leaving the trusted environment? Third, does placeholder-based masking preserve more clinical meaning than full redaction? Fourth, how can the effectiveness of the proxy be evaluated using synthetic prompts, ground-truth PII labels, and observable leakage checks?

C. Contributions

- A modular Python prototype implementing a local anonymization proxy before public LLM inference.
- A hybrid detection pipeline combining regex rules, controlled lists, Microsoft Presidio, spaCy, and SciSpaCy BC5CDR.
- A conflict resolver that avoids double masking and preserves biomedical terms when they are clinically meaningful.
- A typed placeholder masking strategy with date-of-birth generalization into age bands.
- A policy engine using PASS, WARN, and BLOCK decisions for visible PII, quasi-identifier risk, and low-confidence suspicious detections.
- Two LLM gateway modes: mock mode for reproducible evaluation and Groq API mode for real external-LLM demonstration.
- A local response handling pipeline with validator, generic replacement, final output filter, mapping deletion, and audit logging.
- An evaluation workflow using 30 synthetic healthcare prompts and ground-truth PII annotations.

D. Prototype

To study this research question, we develop a prototype anonymization proxy placed between the healthcare application and the external LLM API.



Fig. 1. Processing pipeline of the anonymization proxy from input text to final output.

Fig. 1 shows the internal processing steps of the proxy. The process starts with the input text, which is analyzed using NER-based detection and rule-based checks. Information identified as sensitive is then replaced with placeholders during the masking step. The resulting masked prompt is sent as the LLM request. After the LLM response is received, the proxy performs de-masking using the stored placeholder mapping and produces the final output. This masking and restoration structure is related to prior anonymization frameworks that combine hiding sensitive entities with later de-anonymization of generated results [5]. The prototype allows us to observe the privacy–utility trade-off in practice.

IV. USE CASES

The proposed Anonymization Proxy for Privacy-Preserving LLM Inference can be applied across multiple healthcare workflows where sensitive patient data is processed by external Large Language Model (LLM) APIs. The following use cases illustrate its practical relevance while maintaining compliance with data protection regulations such as GDPR and HIPAA.

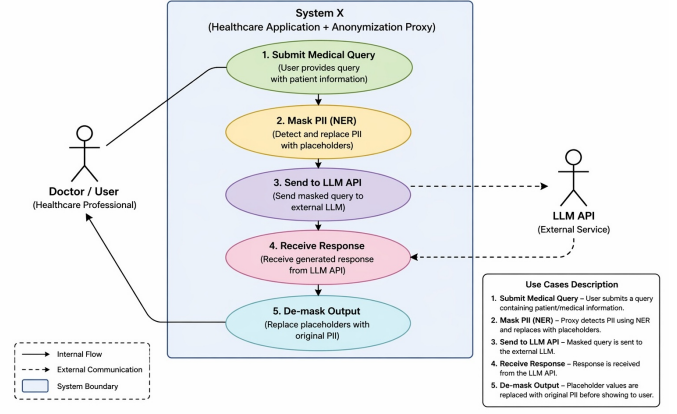


Fig. 2. UML Use Case diagram.

A. Clinical Documentation Assistance

A clinician may want to summarize a short patient note containing names, diagnoses, medications, and hospital references. The proxy masks identifiers and lets the LLM work on the remaining medical context. The final output can use generic labels such as 'the patient' and 'the physician'.

B. Medical Query Assistance for Clinicians

Clinicians may query LLMs for decision support, such as drug interactions, treatment options, or diagnostic insights, often including patient-specific context. The anonymization proxy detects and masks sensitive attributes (e.g., patient identifiers, dates of birth), sends a de-identified query to the LLM and receives and re-contextualizes the response. This allows clinicians to benefit from LLM-driven insights without exposing protected health information (PHI) to third-party services.

C. Appointment and Referral Support

Prompts may ask the LLM to prepare appointment notes or referral summaries. These tasks may mention a doctor name, appointment date, patient's location, symptoms, and hospital. The proxy masks direct identifiers while keeping symptoms such as chest pain, dizziness, or knee pain.

V. PRELIMINARY OR RELATED WORKS

This project is connected to four main areas: prompt privacy protection, clinical de-identification, biomedical named entity recognition, and regulatory privacy principles. Previous prompt privacy approaches show that sensitive information can be sanitized or hidden before user prompts are sent to external LLM services [5], [6]. This idea is especially important in healthcare, where prompts may contain patient names, dates of birth, contact details, locations, medical record numbers, and other protected health information.

Clinical de-identification research shows that identifying information can be removed from medical narratives, but the task remains difficult because clinical text often contains abbreviations, personal names, hospital names, medical

concepts, and context-dependent identifiers [3], [4], [7], [8]. A key challenge is the privacy-utility trade-off: if too little information is masked, private data may leak; if too much information is masked, the clinical meaning of the prompt may be damaged [4].

This problem is visible in the difference between “Dr. Parkinson” and “Parkinson’s disease”. The first should be treated as a person name, while the second should be preserved as a medical condition. Therefore, the final implementation uses biomedical entity detection through SciSpaCy and a conflict resolver to preserve clinical terms while masking identifying information. Similar clinical NLP and de-identification studies use machine learning and transformer-based methods to improve PHI detection in medical text [7]–[9].

The project also considers re-identification risk, because indirect information such as age, location, rare disease, pregnancy status, or small-community references may identify a person even after direct identifiers are removed [10]. Regulatory frameworks such as HIPAA and GDPR further motivate data minimization and anonymization. HIPAA defines categories of health identifiers that should be removed, while GDPR-oriented anonymization requires protection against singling out, linkability, and inference [2], [11]. This prototype follows these privacy-oriented principles, but it does not claim legal certification.

VI. SYSTEM DESIGN

The system follows a staged pipeline as shown in TABLE I. A request handler controls the flow. First, an anonymization session is created. Then PII and medical entities are detected. The conflict resolver selects the best non-overlapping detections. The masking engine replaces identifiers with placeholders and creates a mapping vault. The policy engine checks whether the masked prompt is safe enough for inference. If the prompt passes or warns, the prompt builder prepares the LLM request. The LLM gateway sends it to either the mock model or Groq. The response handler validates the response, applies generic de-anonymization, checks the final output, deletes the mapping vault, and returns a result row for evaluation.

A. Threat Model and Trusted Boundary

The design assumes that the public LLM provider is outside the trusted boundary [5], [6] as shown in Fig. 3. The local proxy, detection engine, masking engine, policy engine, mapping vault, validators, and audit logger are inside the trusted environment. Raw prompts and placeholder mappings should remain inside this local boundary. Only the masked prompt may cross the boundary to the public LLM [11]

VII. COMPONENT-LEVEL IMPLEMENTATION

Fig. 4 shows the main components of the anonymization proxy and the dependencies between them. The system consists of many components that collectively implement the mask-before-API-call and de-mask-after-response-pattern. Incoming requests from the Healthcare Application are received by the Request Handler, which is the entry point of our proxy. The raw prompt is forwarded to the NER Pipeline,

TABLE I
SYSTEM PIPELINE STEPS, FILE MODULES, AND RESPONSIBILITIES

Pipeline step	File/module	Main responsibility
Request handling	request_handler.py	Controls the complete processing pipeline for one prompt.
Session creation	anonymization_session.py	Creates a unique request-scoped session ID and metadata.
Detection	pii_detection_engine.py	Detects direct identifiers, locations, hospitals, dates, and medical terms.
Conflict resolution	conflict_resolver.py	Removes overlaps and selects higher-priority entities.
Masking	masking_engine.py	Replaces PII with placeholders and generalizes date of birth.
Mapping vault	mapping_vault.py	Stores placeholder-to-original mappings locally and temporarily.
Policy check	policy_engine.py	Returns PASS, WARN, or BLOCK before LLM inference.
Prompt building	prompt_builder.py	Adds safe instructions to the masked prompt.
LLM gateway	llm_gateway.py	Routes prompt to mock, Groq, or optional OpenAI backend.
Response handling	response_handler.py	Validates, generically replaces placeholders, filters final output.
Evaluation	evaluator.py, summary_report.py, charts.py	Calculates privacy metrics and prepares summaries/charts.

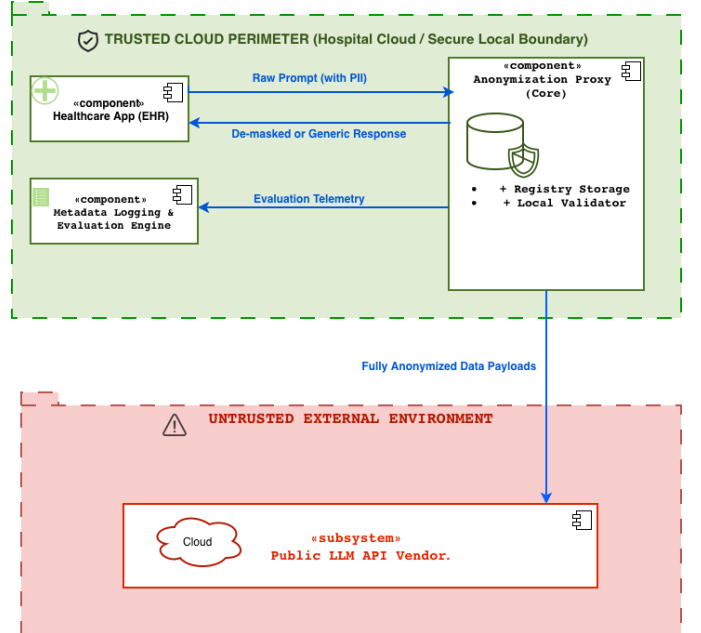


Fig. 3. System Architecture

which performs PII and PHI detection using a hybrid approach combining Microsoft Presidio for general PII recognition. The detected spans are passed to the Anonymizer component, which replaces each identified entity with a placeholder token. The Anonymizer simultaneously writes the token-to-original-value mappings to the Mapping Vault, which stores the mapping information in-memory while the session is still intact.

The anonymized prompt is then forwarded to the LLM Gateway, which sends it to the external Public LLM API via HTTPS. The gateway receives the “tokenized” response and passes it to the Response Handler. The Response Handler forwards the response to the De-Anonymizer, to perform a lookup against the Mapping Vault to restore the original values

and substitutes all placeholder tokens accordingly. Lastly, the de-masked response is then returned to the Request Handler, which delivers it back to the Healthcare Application.

During the whole request lifecycle, the Audit Logger records anonymized metadata without ever storing raw PHI. All privacy-sensitive components operate exclusively within the local perimeter, ensuring that no PHI or PII is transmitted to the external LLM API at any point.

The final prototype is implemented as a Python project. The implementation is intentionally modular so that each architecture component maps to a separate file. This makes the system easier to explain during the lab-course presentation and easier to test component by component.

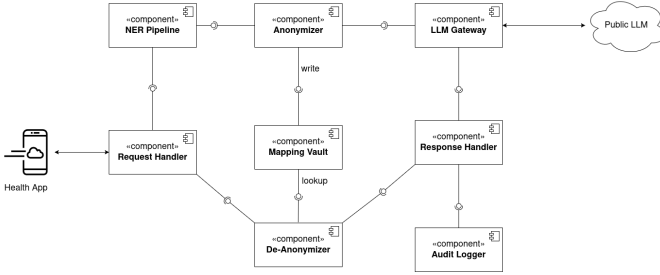


Fig. 4. Component Diagram of our Proxy

A. Request Handler

The request handler is the central controller. It receives one prompt ID, task type, raw prompt, and de-masking mode. It creates the session, calls detection, builds a redaction baseline, masks the prompt, creates the mapping vault, runs the policy check, obtains baseline responses, sends the masked prompt to the LLM gateway when allowed, validates the response, deletes the mapping vault, logs events, and returns a result dictionary. This dictionary is later written to outputs/results.csv.

B. Detection Engine

The detection engine uses a hybrid strategy as represented in TABLE. II. Regex identifies structured values such as emails, phone numbers, exact dates, insurance IDs, medical record numbers, and a known address pattern [7], [8]. Controlled lists detect synthetic patient names, doctor names, locations, and hospital names. spaCy and Presidio add general named-entity and PII detection. SciSpaCy BC5CDR detects biomedical terms such as diseases and chemicals. All detections are combined, duplicates are removed, and overlapping spans are passed to the conflict resolver.

C. Conflict Resolver

The conflict resolver addresses the problem that different tools may label overlapping text differently. It uses a priority system. Structured identifiers such as emails, phone numbers, dates of birth, insurance IDs, MRNs, and addresses receive the highest priority. Known direct identifiers such as patient names, doctor names, locations, and hospitals receive high priority. Biomedical entities receive priority over weaker general NER results because they should usually be preserved.

TABLE II
PII CATEGORIES AND IMPLEMENTED DETECTION METHODS.

Entity category	Example	Implemented detection method	Action
Patient name	John Smith / Müller	Controlled list; spaCy/Presidio	Mask
Doctor name	Dr. Wagner	Controlled list; pattern support	Mask
Phone number	+49 176 12345678	Regex / Presidio	Mask
Email	ben.wagner@example.com	Regex / Presidio	Mask
Date of birth	12.03.1980 or 1980	Regex and context rule	Generalize to age group
Insurance ID	A123456789	Regex	Mask
Medical record number	MRN-883921	Regex	Mask
Location	Munich	Controlled list / NER	Mask
Hospital	Charite Berlin	Controlled list / NER	Mask
Disease	diabetes, ALS, Parkinson disease	SciSpaCy BC5CDR	Preserve
Medication / chemical	Metformin, insulin	SciSpaCy / keyword support	Preserve

Presidio and spaCy results remain useful, but they are lower priority when they conflict with stronger direct identifiers or medical concepts. A key example is the difference between 'Karl Parkinson' and 'Parkinson's disease'. The first is a patient name and should be masked. The second is a disease and should be preserved. Without conflict resolution, the system could produce corrupted text such as '[PERSON_1]'s disease'. The final resolver prevents this by selecting the most appropriate non-overlapping span.

D. Masking Engine and Age Generalization

The masking engine performs the actual anonymization. Direct identifiers are replaced by typed placeholders such as [PATIENT_NAME_1], [PHONE_1], [MEDICAL_RECORD_ID_1], or [INSURANCE_ID_1]. Dates of birth are not simply removed; they are converted into approximate age bands such as 'age group 40s' as represented in TABLE III. This preserves some clinical context while removing the exact date. Age expressions such as '32-year-old' and 'age 7' can be preserved as clinically relevant quasi-identifiers, while the policy engine can warn when age combines with other risky factors. Entities are masked from the end of the text toward the beginning. This is important because replacement changes string length. If the system masked from left to right, later character offsets could become invalid. Right-to-left replacement keeps earlier offsets stable.

E. Mapping Vault Lifecycle

The mapping vault stores the relationship between placeholders and original values. For example, [PATIENT_NAME_1] maps to the original patient name. The vault is session-scoped and remains inside the trusted proxy. It is never sent to the public LLM. After response handling or after a policy block, the request handler calls delete_mapping_vault(vault), which clears the in-memory dictionary and logs MAPPING_VAULT_DELETED. FIG. 5 demonstrates temporary mapping lifecycle. In production, stronger secure deletion and encrypted storage would be

TABLE III
EXAMPLES OF MASKING STRATEGIES AND CONTEXT PRESERVATION

Original value	Masked value	Reason
John Smith	[PATIENT_NAME_1]	Patient name is direct PII.
+49 176 12345678	[PHONE_1]	Phone number is direct PII.
MRN-883921	[MEDICAL_RECORD_ID_1]	Medical record number is direct PII.
A123456789	[INSURANCE_ID_1]	Insurance ID is direct PII.
12.03.1980	age group 40s	Exact DOB is identifying; age band preserves context.
diabetes	diabetes	Disease term is clinically meaningful and preserved.

required, and mappings would not be exported in result CSV files.

```

2026-08-03T18:58:17,85dbbac8-be09-4c1b-8206-6a5853ba624f,DEMO_001,SESSION_CREATED,New anonymization session created.
2026-08-03T18:58:17,85dbbac8-be09-4c1b-8206-6a5853ba624f,DEMO_001,PII_DETECTED,Detected 4 entities.
2026-08-03T18:58:17,85dbbac8-be09-4c1b-8206-6a5853ba624f,DEMO_001,PROMPT_MASKED,Prompt was masked and mapping was stored in local session vault.
2026-08-03T18:58:17,85dbbac8-be09-4c1b-8206-6a5853ba624f,DEMO_001,POLICY_CHECK,Policy decision: PASS
2026-08-03T18:58:17,85dbbac8-be09-4c1b-8206-6a5853ba624f,DEMO_001,LLM_RESPONSE_RECEIVED,Received response from LLM gateway.
2026-08-03T18:58:17,85dbbac8-be09-4c1b-8206-6a5853ba624f,DEMO_001,RESPONSE_VALIDATED,Validator decision: PASS
2026-08-03T18:58:17,85dbbac8-be09-4c1b-8206-6a5853ba624f,DEMO_001,MAPPING_VAULT_DELETED,Session mapping vault was deleted after response handling.
2026-08-03T11:11:25,1c9a7a15-6a9a-4c95-987d-f9da48239a3b,DEMO_001,SESSION_CREATED,New anonymization session created.
2026-08-03T11:11:30,1c9a7a15-6a9a-4c95-987d-f9da48239a3b,DEMO_001,PII_DETECTED,Detected 4 entities.
2026-08-03T11:11:30,1c9a7a15-6a9a-4c95-987d-f9da48239a3b,DEMO_001,PROMPT_MASKED,Prompt was masked and mapping was stored in local session vault.
2026-08-03T11:11:30,1c9a7a15-6a9a-4c95-987d-f9da48239a3b,DEMO_001,POLICY_CHECK,Policy decision: PASS
2026-08-03T11:11:30,1c9a7a15-6a9a-4c95-987d-f9da48239a3b,DEMO_001,LLM_RESPONSE_RECEIVED,Received response from LLM gateway.
2026-08-03T11:11:30,1c9a7a15-6a9a-4c95-987d-f9da48239a3b,DEMO_001,RESPONSE_VALIDATED,Validator decision: PASS
2026-08-03T11:11:30,1c9a7a15-6a9a-4c95-987d-f9da48239a3b,DEMO_001,MAPPING_VAULT_DELETED,Session mapping vault was deleted after response handling.

```

Fig. 5. Mapping vault lifecycle.

F. LLM Gateway

The LLM gateway makes the backend configurable. If LLM_MODE is not set, the system uses mock mode. If LLM_MODE is set to groq, the gateway sends the masked prompt to the Groq API. Optional OpenAI support is present, but the final demo used Groq because it was easier to run within project constraints. The Groq API key is read from an environment variable and is not stored in the source code. This prevents API secrets from being pushed to GitLab.

Groq is not used to benchmark LLM quality. It is used as one proof-of-integration backend. The purpose is to demonstrate that the proxy can safely connect to an external LLM provider while sending only the masked prompt. Mock mode remains the main evaluation mode because it is reproducible, deterministic, free, and independent of network or API limits.

G. Response Validation and Final Filtering

The local response validator checks the raw LLM response before generic replacement or restore-mode processing. It searches for email-like patterns, phone-like patterns, exact dates, insurance IDs, MRNs, and selected unsafe medical phrases such as 'stop taking medication' or 'double the dose'. If any issue is detected, the response is blocked. After placeholder handling, the final output filter performs another leakage check. This two-layer output-side protection is important because a real public LLM can generate unexpected text. The validator is intentionally described as a lightweight rule-based guardrail. It is not a full medical fact-checker. It does not prove clinical correctness, and it cannot detect every hallucination. Full medical fact verification is listed as future work.

H. Anonymization Session

Each prompt receives a unique request-scoped session. The session contains a UUID session_id, prompt_id, task_type, timestamp, demasking_mode, and status. This structure separates the lifecycle of one prompt from another and connects audit events and mappings to the correct request.

I. Policy Engine

The policy engine is the input-side safety gate. It receives the masked prompt and the detected entities, then returns a decision. BLOCK is used when direct PII remains visible after masking, such as an email, phone number, exact date, insurance ID, MRN, or street address. WARN is used when quasi-identifier combinations create re-identification risk or when Presidio/spaCy produce low-confidence suspicious detections. PASS is used when no visible PII or significant risk is found as depicted in TABLE. IV.

TABLE IV
POLICY ENGINE DECISION FRAMEWORK

Decision	Meaning	Example trigger
PASS	Prompt is safe to send.	No direct PII remains and no major quasi-risk is found.
WARN	Prompt can continue, but risk is visible.	Pregnancy + age + gender; ALS + small village; low-confidence suspicious entity.
BLOCK	Prompt is not sent to LLM.	Visible phone number, email, exact date, MRN, insurance ID, or address remains.

VIII. EXPERIMENTAL SETUP

A. Dataset

The evaluation uses 30 synthetic healthcare prompts as explained in TABLE. V. The prompts cover medical summarization, patient explanation, appointment preparation, referral support, lab result explanation, medication summary, rare disease risk cases, and mixed identifier cases. The dataset includes fictional PII and medically relevant concepts. It also includes edge cases such as MRNs, insurance IDs, hospital names, rare diseases, pregnancy, age, small-location context, and ambiguous Parkinson-related terms.

B. Baseline Conditions

To evaluate the effectiveness of the proposed anonymization approach, the system is compared against baseline prompt-processing strategies. The purpose of this comparison is to determine whether placeholder-based masking provides a better balance between privacy protection and response quality than simpler alternatives.

Three conditions are considered in the evaluation as shown in FIG. 6

- **Original Prompt Baseline:** The original synthetic prompt is sent to the LLM without masking. This condition provides the highest amount of context and is used

TABLE V
SYNTHETIC PROMPT CATEGORIES

Category	Examples in dataset
Medical summarization	Diabetes, asthma, pneumonia, cholesterol, low hemoglobin
Patient explanation	Hypertension, HbA1c, Parkinson disease, depression symptoms
Appointment preparation	Knee pain, migraine follow-up, appointment date
Referral support	Chest pain, dizziness, doctor referral, location masking
Identifier stress tests	Email, phone, insurance ID, MRN, street address
Quasi-identifier tests	Pregnancy + age + gender, ALS + small village, Huntington disease + very old age
Ambiguity tests	Karl Parkinson vs Parkinson disease

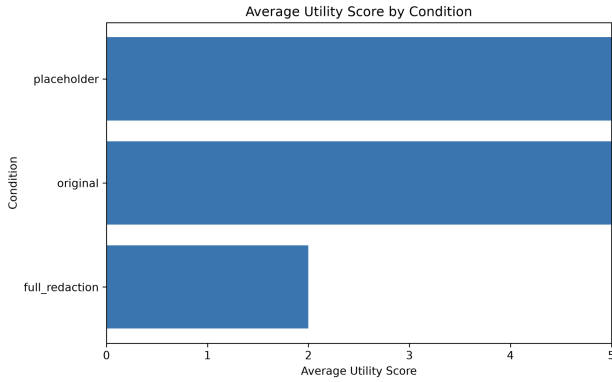


Fig. 6. Average Utility score by condition.

as a reference for answer quality. However, it does not provide privacy protection and is therefore only used in controlled experiments with synthetic data.

- **Full Redaction Baseline:** All detected PII entities are removed or replaced with generic redaction tokens such as [REDACTED]. This condition provides strong privacy protection, but it may reduce the context available to the LLM because the role or type of the removed information is not always preserved.
- **Placeholder-Based Masking:** Detected PII entities are replaced with typed placeholders such as [PATIENT_NAME_1], [DATE_OF_BIRTH_1], or [LOCATION_1]. This is the proposed approach. It aims to protect privacy while preserving the structure and meaning of the original prompt.

The expected trade-off between the three conditions is shown in Table. VI.

For each synthetic prompt, the LLM response is generated under each condition and then evaluated using the privacy metrics and utility metrics described above. The original prompt baseline is used to estimate the maximum achievable response quality, while the full redaction baseline shows how much utility may be lost when contextual information is removed too aggressively. The proposed placeholder-based masking approach is expected to achieve a lower PII leakage rate than

the original prompt baseline and better response quality than the full redaction baseline.

TABLE VI
BASELINE COMPARISON CONDITIONS

Condition	Privacy expectation	Utility expectation	Purpose
Original prompt	Low	High	Reference for full context; synthetic-only
Full redaction	High	Low to medium	Shows loss caused by aggressive removal
Placeholder masking	High	Medium to high	Main proposed privacy-utility trade-off

C. Evaluation Metrics

The implemented privacy evaluator compares outputs/results.csv against data/ground_truth_pii.csv. For each prompt, it reads detected_entities and masked_prompt. It then checks whether each ground-truth PII value was detected and whether any original PII value still appears in the masked prompt. Two main automatic metrics are produced: PII recall and leakage rate.

$$\text{PII Recall} = \frac{\text{correctly detected PII}}{\text{total ground-truth PII}} \quad (1)$$

$$\text{Leakage Rate} = \frac{\text{leaked PII in masked prompt}}{\text{total ground-truth PII}} \quad (2)$$

Utility evaluation is treated differently. Because usefulness, completeness, medical safety, and hallucination risk are difficult to judge reliably using simple automatic rules, a utility_evaluation_template.csv file is prepared for manual or expert scoring. The final prototype does not claim completed expert-rated utility scoring. Instead, utility is discussed using context preservation examples and mock-vs-redaction comparisons.

- **Relevance:** Measures whether the response directly addresses the user query and remains focused on the requested healthcare task.
- **Completeness:** Measures whether the response includes the important medical information from the input prompt without omitting key context.
- **Coherence:** Measures whether the response is understandable, logically structured, and written in a clear form.
- **Context Preservation:** Measures whether the anonymized prompt still allows the LLM to use medically relevant information, such as symptoms, diagnoses, medication names, and treatment-related details.
- **Placeholder Handling:** Measures whether the LLM correctly preserves or uses placeholders such as [PATIENT_NAME_1], [DATE_OF_BIRTH_1], or [LOCATION_1] without inventing new identities.
- **Hallucination Risk:** Measures whether the response introduces unsupported claims or facts that are not present in the input prompt.

For example, a 32-year-old pregnant female patient may be clinically relevant but sensitive, and ALS with a small-location context creates high re-identification risk.

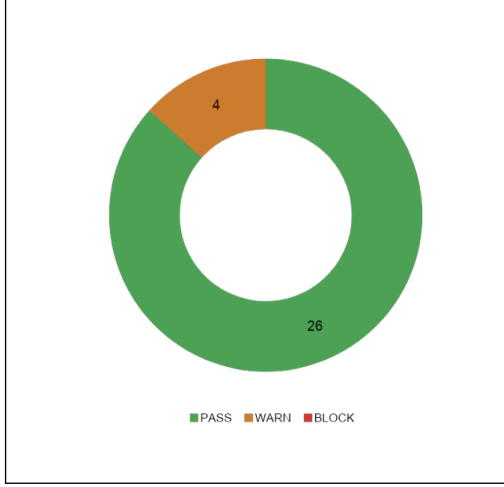


Fig. 10. Policy Decision Counts.

C. Medical Context Preservation

The placeholder method as shown in TABLE VII preserves useful medical context. For example, MRNs and insurance IDs are masked, while insulin, diabetes, Parkinson’s disease, pneumonia, and ALS remain visible. This behavior is essential for the research question because the goal is not to hide all words, but to remove identity while preserving meaning.

TABLE VII
MEDICAL CONTEXT PRESERVATION

Prompt example	Privacy action	Preserved clinical context
P009	MRN-883921 masked as [MEDICAL_RECORD_ID_1]	insulin for diabetes
P013	Insurance ID masked	Parkinson’s disease
P017	Patient name masked; policy WARN	32-year-old pregnant female context
P028	Patient and location masked; policy HIGH/WARN	ALS and small-village risk context

D. Privacy Evaluation

The final evaluation reports that the system successfully masks direct identifiers in the controlled synthetic dataset. The key privacy result is not that the model understands healthcare, but that ground-truth identifiers are detected and do not remain visible in the masked prompt. In the final 30-prompt dataset, the expected summary is 26 PASS decisions, 4 WARN decisions, and 0 BLOCK decisions after successful masking. WARN cases correspond to quasi-identifier combinations rather than direct PII leakage.

E. Groq API Demonstration

Groq mode demonstrates that the same anonymization pipeline can call a real external LLM. In this mode, the LLM gateway sends only the masked prompt to Groq. The raw prompt and mapping vault remain local. The Groq run was also performed for all prompts, but its responses are inspected

separately because a public LLM may refuse medical content, vary in wording, or add unsupported details. This is an expected limitation of real LLM integration and motivates the response validator.

XI. DISCUSSION

The results support the main design idea: a local proxy can reduce direct PII exposure while preserving medical utility. The strongest part of the prototype is the separation between direct identifiers and clinical terms. Regex and controlled lists are reliable for structured test cases, while Presidio and spaCy add broader general detection. SciSpaCy is important because it helps prevent medical terms from being over-masked. The conflict resolver is central to the privacy-utility trade-off. Without conflict resolution, a general NER tool may treat parts of disease names as person names, causing useful clinical context to be removed. Conversely, without structured identifier priority, a term such as MEDICAL_RECORD_ID could be mistakenly preserved because it contains the word medical. The implemented priority system avoids this by preserving only SciSpaCy biomedical concepts while still masking medical record numbers. The mapping vault demonstrates temporary local state. This is important because placeholders alone are safe, but placeholders plus mappings are sensitive. In the prototype, mapping deletion is implemented by clearing the dictionary after response handling. This demonstrates the lifecycle but should not be confused with full secure memory deletion in a production system.

XII. LIMITATIONS

- The dataset is synthetic and controlled. Real clinical text would contain more variation, errors, abbreviations, and unexpected formats.
- Some detection rules are dataset-specific, for example controlled name lists and selected address patterns.
- The utility evaluation template is prepared, but full human/expert utility scoring is not completed automatically.
- The response validator is rule-based and is not a full medical fact checker or hallucination detector.
- Groq mode depends on external API availability, rate limits, API keys, model behavior, and internet connection.
- The mapping vault is in-memory and prototype-level. Production would require encryption, access control, secure deletion, and no mapping export in result files.
- Low-confidence blocking is implemented as a warning mechanism rather than a full confidence-threshold blocking system.
- Privacy metrics use exact text matching and are appropriate for the synthetic dataset, but real-world evaluation would need more flexible matching and expert validation.

XIII. CONCLUSION

This project implemented a privacy-preserving LLM proxy for healthcare prompts. The prototype processes raw prompts locally, detects PII and biomedical terms, resolves conflicts, masks identifiers, checks policy, sends only anonymized prompts to the selected LLM backend, validates the response,

replaces placeholders using generic labels, filters final output, deletes the mapping vault, and logs metadata. For the synthetic dataset, the system demonstrates that direct identifiers can be masked while preserving clinically meaningful context. The mock backend supports reproducible evaluation, and the Groq backend demonstrates real public LLM integration. The main conclusion is that a local anonymization proxy can reduce direct PII exposure while preserving enough context for useful LLM-assisted documentation in a controlled prototype setting. Production deployment would require stronger security, broader detection, expert utility evaluation, and formal compliance review.

For each synthetic prompt, the LLM response is generated under each condition and then evaluated using the privacy metrics and utility metrics described above. The original prompt baseline is used to estimate the maximum achievable response quality, while the full redaction baseline shows how much utility may be lost when contextual information is removed too aggressively.

The proposed placeholder-based masking approach is expected to achieve a lower PII leakage rate than the original prompt baseline and better response quality than the full redaction baseline. This comparison directly supports the research question by measuring whether anonymization can protect PII without destroying the context required for useful LLM inference.

REFERENCES

- [1] S. Cheng *et al.*, “Understanding pii leakage in large language models: A systematic survey,” in *Proc. Int. Joint Conf. Artif. Intell. (IJCAI)*, 2025.
- [2] U.S. Department of Health and Human Services, Office for Civil Rights, “Guidance regarding methods for de-identification of protected health information in accordance with the hipaa privacy rule,” U.S. Dept. Health Human Serv., Tech. Rep., 2012.
- [3] A. Stubbs, C. Kotfila, and O. Uzuner, “Automated systems for the de-identification of longitudinal clinical narratives: Overview of 2014 i2b2/uthealth shared task track 1,” *J. Biomed. Inform.*, vol. 58, pp. S11–S19, 2015.
- [4] S. M. Meystre, O. Ferrandez, J. Friedlin, B. R. South, S. Shen, and M. H. Samore, “Text de-identification for privacy protection: A study of its impact on clinical text information content,” *J. Biomed. Inform.*, vol. 50, pp. 142–150, 2014.
- [5] Y. Chen, T. Li, H. Liu, and Y. Yu, “Hide and seek (has): A lightweight framework for prompt privacy protection,” *arXiv preprint arXiv:2308.11808*, 2023.
- [6] C. J. Chong, C. Hou, Z. Yao, and S. N. S. Talebi, “Casper: Prompt sanitization for protecting user privacy in web-based large language models,” in *Proc. IEEE 12th Int. Conf. Cyber Secur. Cloud Comput. (CSCloud)*, 2025, pp. 122–133.
- [7] F. Dernoncourt, J. Y. Lee, O. Uzuner, and P. Szolovits, “De-identification of patient notes with recurrent neural networks,” *J. Am. Med. Inform. Assoc.*, vol. 24, no. 3, pp. 596–606, 2017.
- [8] A. E. W. Johnson, L. Bulgarelli, and T. J. Pollard, “Deidentification of free-text medical records using pre-trained bidirectional transformers,” in *Proc. ACM Conf. Health, Inference, and Learning*, 2020, pp. 214–221.
- [9] S. Liu *et al.*, “De-identification of protected health information from clinical narratives using large language models,” *J. Biomed. Inform.*, vol. 152, p. 104618, 2024.
- [10] B. Manzanares-Salor, D. Sánchez, and P. Lison, “Evaluating the disclosure risk of anonymized documents via a machine learning-based re-identification attack,” *Data Min. Knowl. Discov.*, vol. 38, no. 6, pp. 4049–4075, 2024.
- [11] Article 29 Data Protection Working Party, “Opinion 05/2014 on anonymisation techniques,” European Commission, Tech. Rep. WP216, 2014.